

State of Maine
Department of Administrative and Financial Services
Office of Information Technology

Planning Policy and Procedures (PL)

Planning Policy and Procedures (PL)

Table of Contents

1.0. Document Purpose 2

2.0. Scope 2

3.0. Policy Conflict 2

4.0. Roles and Responsibilities 2

5.0. Management Commitment 2

6.0. Coordination Among Agency Entities 3

7.0. Compliance 3

8.0. Procedures 3

9.0. Document Details 7

10.0. Review 8

11.0. Records Management 8

12.0. Public Records Exceptions 8

13.0. Definitions 8

14.0. Abbreviations 9

1.0. Document Purpose

The purpose of this document is to define the State of Maine policy and procedures that are in place to develop and manage security planning processes to reduce risk for State of Maine information assets (see Definitions). This part of the security program is focused on protecting the confidentiality (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets. This document corresponds to the Planning Policy and Procedures (PL) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1].

2.0. Scope

2.1. This policy applies to all State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Policy Conflict

If this policy conflicts with any law or union contract in effect, the terms of the existing law or contract prevail.

4.0. Roles and Responsibilities

4.1. Agency Business Partners:

4.1.1. Cooperate with the Office of Information Technology (OIT) Information Security to develop system security plans.

4.1.2. Develop and implement agency-level policy and procedures to meet additional statutory requirements or agency-specific controls.

4.1.3. Ensure that personnel comply with information security training requirements and are trained in and agree to the Rules of Behavior (PL-4).[2]

4.2. OIT Information Asset Owners:

4.2.1. Comply with this Planning Policy and Procedures document.

4.3. OIT Information Security:

4.3.1. Owns, executes, and enforces this Planning Policy and Procedures.

5.0. Management Commitment

The State of Maine is committed to following this policy and the procedures that support it.

---

[1] https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/RulesofBehavior.pdf

6.0. Coordination Among Agency Entities

6.1. OIT assists agencies in the development of the required system security plans and in meeting their information security architecture needs. Additionally, as required by statute, OIT establishes and maintains the minimum Rules of Behavior[3] for information system (see Definitions) users.

6.2. Agencies may add requirements to the Rules of Behavior to meet specific agency needs but cannot remove requirements as established by OIT.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine's data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement, and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to, and represent, the security controls established to meet an acceptable level of protection for, State of Maine to implement security planning to manage risk.

8.1. System Security Plans (PL-2)

8.1.1. OIT Information Security assists the agencies (and vendors) in the development of System Security Plans (SSPs) to meet Federal regulatory requirements and as otherwise required.

8.1.2. OIT subscribes to a security architecture using NIST SP 800-53 security control and control enhancements. The collective body of all plans, policies, and procedures that documents each NIST control family (e.g., Access Control, Planning, Security Assessments) acts as the enterprise level SSP.

8.1.3. OIT assists Maine Department of Health and Human Services (DHHS) to develop SSPs and comply with the mandates of the Patient Protection and Affordable Care Act of 2010, as determined by the Centers for Medicare and Medicaid Services.

[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/RulesofBehavior.pdf

8.1.4. OIT also assists the following agencies that receive Federal Taxpayer Information (FTI) and/or Controlled Unclassified Information (CUI) from the Social Security Administration (SSA) (see Definitions) in the preparation of their respective SSPs as determined by the Internal Revenue Services (IRS) and the SSA:

8.1.4.1. DHHS;

8.1.4.2. Maine Department of Labor (DOL), and

8.1.4.3. Maine Department of Administrative and Financial Services (DAFS) Maine Revenue Services (MRS).

8.1.5. As outlined in IRS Publication 1075, Safeguards for Protecting Federal Tax Returns and Return Information, an approved and accurate Safeguard Security Report (SSR), satisfies the requirement of the SSP. The SSR is required to be submitted to the IRS annually by May 31.

8.1.6. OIT Assists DHHS and DOL with the completion of the Security Evaluation Questionnaire (SEQ), the Security Requirements Traceability Matrix (SRTM), and SSPs that are deemed integral parts of the compliance review process for the SSA.

8.1.6.1. SEQs are required when there are changes to the data exchange or the application receiving the data, and prior to both on-site and remote assessments.

8.1.6.2. SRTMs document the system's security requirements for various NIST controls and list the artifacts and evidence required for assessments. SRTMs are required prior to assessments and when security control implementations change due to application or data exchange enhancements.

8.1.6.3. SSPs that detail how security controls are implemented are required for assessments.

8.2. Rules of Behavior (PL-4, (1))

8.2.1. The Rules of Behavior for the Information Security Policy govern the individual behavior of personnel for the appropriate access to and use of State of Maine assets. See the Rules of Behavior (PL-4)[4] for more information.

[4] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/RulesofBehavior.pdf

8.3. Information Security Architecture (PL-8, related to PM-7)

8.3.1. OIT, in its General Architecture Principles,[5] outlines guidance to aid in everyday decision making that:

8.3.1.1. Describes the overall philosophy, requirements, and approach to be taken with regard to protecting the confidentiality, integrity, and availability of information. One of the eight principles established is that "Security and Privacy are foundational to everything else." The State implements security and privacy best practices at all levels of government to ensure the confidentiality, integrity, and availability of its information assets;

8.3.1.2. Describes how the information security architecture is integrated into and supports the enterprise architecture. OIT describes security in the General Architecture Principles as foundational;

8.3.1.3. Describes any information security assumptions about, and dependencies on, external services.

8.3.1.3.1. Another principle is that "The State is a single, unified enterprise." This principle is used to maximize resources and as a basis for effective disaster recovery.

8.3.1.3.2. The principle to "First reuse; then buy; then build," "Centralize Authentication; Federate Authorization," and "Be Cloud Smart" describes interdependency considerations. The principle of "Choose new products carefully" states that the top product selection criteria are cybersecurity, privacy, and accessibility.

8.3.2. Information security architecture is designed using a defense-in-depth approach, which strategically allocates safeguards that operate in a coordinated and mutually reinforcing manner so that adversaries must overcome multiple safeguards to achieve their objective. (See System and Communications Protection Procedures for Defense in Depth)[6]

8.3.3. Security architecture for information systems is consistent with the OIT information security plans, policies, and procedures,[7] which establish the minimum benchmark and implement controls to protect State information assets from unauthorized use, disclosure, modification, and

[5] https://www.maine.gov/oit/architecture/documents/GeneralArchitecturePrinciples.pdf
[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCDefenseInDepthProcedures.pdf
[7] https://www.maine.gov/oit/policies/

destruction, and ensures confidentiality, integrity, and availability of information assets.

8.3.3.1. OIT also implements NIST standards and controls into policy, with which the security architecture of information systems is compliant.

8.3.3.2. Other policies, including but not limited to the Network Device Management Policy,[8] the Remote Hosting Policy,[9] the User Device and Commodity Application Policy,[10] and Mobile Device Policy,[11] ensure the security of State information assets. All public OIT policies can be found at https://www.maine.gov/oit/policies/.

8.3.3.3. Any information system that is not compliant with OIT policies must go through a rigorous waiver process managed by Enterprise Architecture and Security, and including other relevant subject matter experts in order to ensure the presence of compensating controls and confirm that the information system as well as all State of Maine information assets are secure and protected. See the Waiver Policy[12] for more information.

8.3.4. Enterprise Architecture, in collaboration with Security, Compliance, IT Procurement, and other relevant parties, vets all proposed new technologies and technology solutions regarding security to ensure that new products and technologies align with the State of Maine's overall security architecture.

8.3.5. IT Procurement, in collaboration with Enterprise Architecture, Security, Compliance, and other relevant parties, vets all technology-related procurement contracts, both new and renewed, through contract review to ensure that contracts align with the State of Maine's overall security architecture.

8.3.6. Information security architecture is updated as needed to reflect changes in enterprise architecture.

8.3.7. Acquisition-related documents and security plans are updated as needed to reflect changes in the information security architecture.

8.3.8. Defense in Depth (PL-8(1))

8.3.8.1. OIT has deployed a defense-in-depth approach by utilizing multiple overlapping layers of security controls to protect

[8] https://www.maine.gov/oit/policies/NetworkDeviceManagementPolicy.pdf
[9] https://www.maine.gov/oit/policies/RemoteHostingPolicy.pdf
[10] https://www.maine.gov/oit/policies/UserDeviceCommodityAppPolicy.pdf
[11] https://www.maine.gov/oit/policies/MobileDevicePolicy.pdf
[12] https://www.maine.gov/oit/policies/waiver.pdf

information assets and systems. Each layer serves a specific role in mitigating risks, ensuring that if one layer is compromised, others will continue to provide protection.

8.3.8.1.1. In addition to security controls, including those at the physical, network, endpoint, application, and data layers, OIT enforces strong authentication methods and monitors networks and systems for suspicious activity.

8.4. Central Management (PL-9)

8.4.1. State of Maine information security is centrally managed and is mandated by the State of Maine revised statue[13], which establishes the OIT and Chief Information Officer (CIO) roles and responsibilities to direct the information security program.

8.4.1.1. The Chief Information Security Officer (CISO) roles and responsibilities are based off the CIO statute-defined roles and responsibilities to assist in the coordination and implementation of the State of Maine's information security management system.

8.5. Security baseline selection (PL-10)

8.5.1. OIT adheres to select controls outlined in NIST SP 800-53 Rev 5 to establish comprehensive enterprise policies, plans, and procedures. These translate into a baseline configuration that ensures compliance with legal mandates, executive orders, directives, regulations, and industry standards, while also addressing common threats faced by all users within the specific assumptions of the baseline.

8.6. Security baseline tailoring (PL-11)

8.6.1. This approach outlined in PL-10 resulted in a moderate to high baseline of our own design, tailored to meet specific security requirements while ensuring compliance with applicable laws, regulations, and industry standards. Additionally, we leverage other established baselines from vendors, best practices, and organizations like CIS to further strengthen our security posture across all manners of technology.

9.0. Document Details

9.1. Initial Issue Date: June 24, 2020
9.2. Latest Revision Date: October 3, 2025
9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov
9.4. Approved By: Chief Information Officer, OIT

[13] https://legislature.maine.gov/statutes/5/title5ch163sec0.html

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[14]
9.6. Waiver Process: Waiver Policy[15]
9.7. Distribution: Internet[16]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[17] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[18] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as to security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Availability: Timely and reliable access to and use of information assets.

13.2. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.

13.3. Controlled Unclassified Information (CUI): Information provided by the Social Security Administration (SSA) to state agencies. The data includes requested Social Security Number (SSN) verifications, along with benefit information. Pursuant to 32 C.F.R. 2002.16(a)(6), the state agencies must safeguard CUI in accordance with Executive Order 13556, 32 C.F.R. Part 2002 and the CUI Registry and is subject to SSA oversight. This data may also include Personally Identifiable Information (PII).

[14] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[15] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[16] https://www.maine.gov/oit/policies-standards
[17] https://www.maine.gov/sos/arc/records/state/GS1Administrative.pdf
[18] https://legislature.maine.gov/statutes/1/title1sec402.htm

The SSA's Technical System Security Requirements[19] detail the requirements and procedures for state agencies that exchange SSA data electronically.

13.4. Federal Taxpayer Information (FTI): Federal tax returns and return information (and information derived from it) that is in the agency's possession or control which is received directly from the IRS (or obtained through an authorized secondary source), covered by the confidentiality protections of the Internal Revenue Code (IRC), and subject to the IRC 6103(p)(4) safeguarding requirements including IRS oversight. FTI may contain Personally Identifiable Information (PII) IRS Publication 1075.[20]

13.5. Information system: Used interchangeably with Information System. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.6. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.7. Personally Identifiable Information (PII): Information that can be used to distinguish or trace the identity of an individual (for example, name, SSN, biometric records, and so on) alone, or when combined with other personal or identifying information that is linked or linkable to a specific individual (such as date and place of birth, mother's maiden name, etc.). It also includes personal information protected from disclosure under Federal or State privacy laws.[21]

14.0. Abbreviations

14.1. CIO: Chief Information Officer

14.2. CISO: Chief Information Security Officer

14.3. CUI: Controlled Unclassified Information

14.4. DHHS: Department of Health and Human Services

14.5. DOL: Department of Labor

14.6. FOAA: (Maine) Freedom of Access Act

14.7. FTI: Federal Taxpayer Information

14.8. IRC: Internal Revenue Code

14.9. IRS: Internal Revenue Service

14.10. NIST: National Institute of Standards and Technology

---

[19] https://www.ssa.gov/dataexchange/eCBSV/documents/ua/eCBSV%20User%20Agreement%20-%20Technical%20Specifications%20and%20Systems%20Security.pdf

[20] https://www.irs.gov/pub/irs-pdf/p1075.pdf

[21] https://csrc.nist.gov/glossary

14.11. OIT: Office of Information Technology

14.12. SEQ: Security Evaluation Questionnaire

14.13. SRTM: Security Requirements Traceability Matrix

14.14. SSA: Social Security Administration

14.15. SSP: System Security Plan

14.16. SSR: Safeguard Security Report